# 1. Target System Description & Setup Evidence

## 1.1 Selected Vulnerable Systems

**Name & Source:** Kioptrix Level 1 (VulnHub)

Kioptrix Level 1 is a deliberately vulnerable Linux-based virtual machine designed for security training and penetration testing practice.

## 1.2 Reason for Choosing It

The target system was selected because it contains multiple known vulnerabilities and outdated services that can be analyzed in a controlled environment. It provides an effective platform for performing network discovery, traffic analysis, authentication evaluation, and security assessment activities required for this project.

## 1.3 Virtual Machine Setup

A new virtual machine named **Kioptrix_1** was created in Oracle VirtualBox. Since Kioptrix Level 1 was provided with a preconfigured virtual disk, the existing VMDK file was attached to the virtual machine instead of installing a new operating system.

## 1.4 System Configuration

The virtual machine was configured with appropriate hardware settings, including memory allocation, boot configuration, and storage settings. The attached virtual disk was connected through the IDE controller to ensure compatibility with the target operating system.

## 1.5 Network Configuration

The network adapter was enabled and connected to the dedicated NAT Network (**NetSec**). This configuration allowed secure communication between the Kali Linux auditor machine and the target system while maintaining isolation from external networks.

## 1.6 Target VM Verification

After completing the configuration process, the Kioptrix Level 1 virtual machine was successfully booted. The login interface was displayed correctly, confirming that the target system was operational and ready for security assessment.

A new virtual machine named **Kioptrix_1** was created in Oracle VirtualBox to host the vulnerable target system for security assessment.

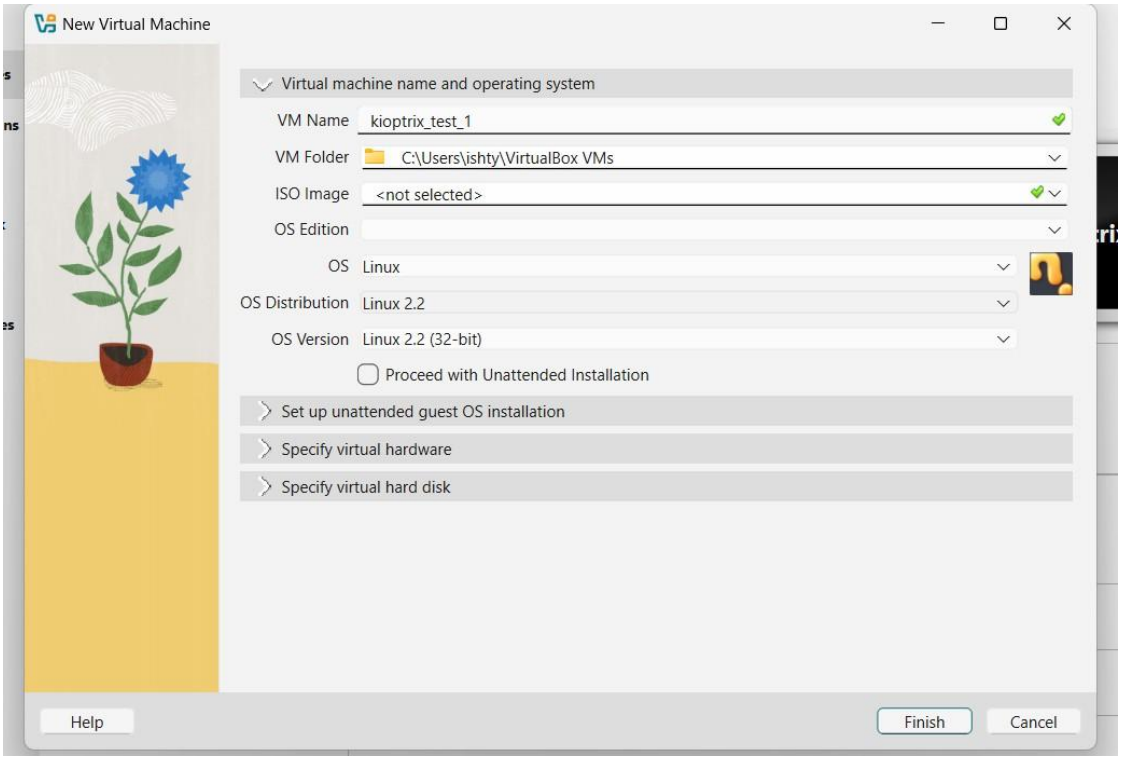



Fig : Creating the Virtual Machine

The existing **Kioptrix Level 1.vmdk** virtual hard disk was selected and attached during the virtual machine setup process.

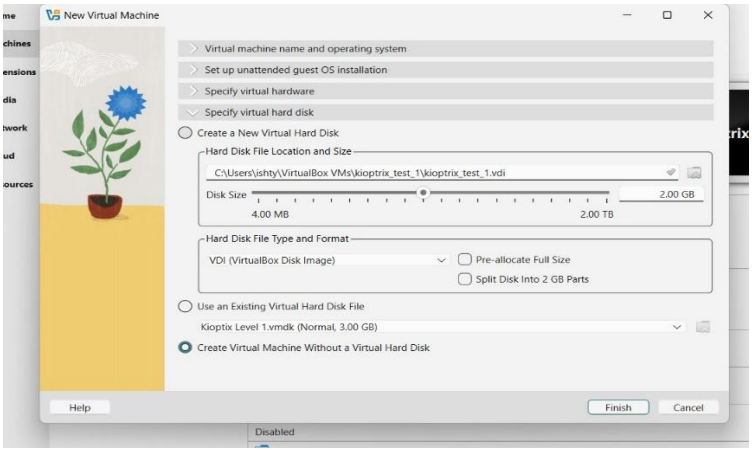



Fig : Selecting the Existing Virtual Disk

The attached VMDK file was configured through the IDE controller in the Storage settings of VirtualBox.

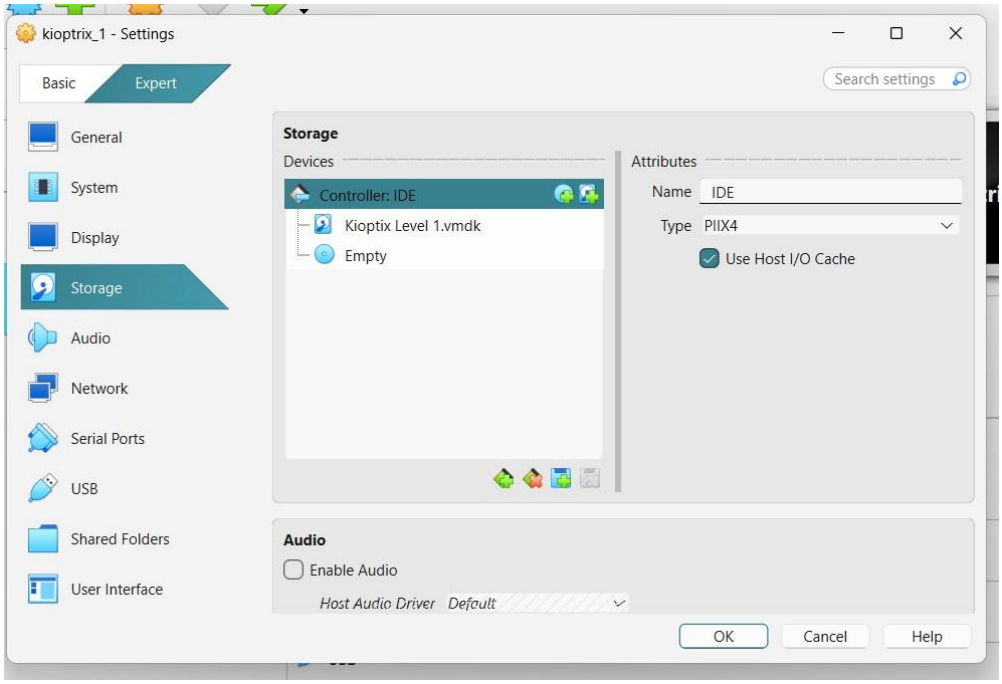



Fig : Storage Configuration

The attached VMDK file was configured through the IDE controller in the Storage settings of VirtualBox.

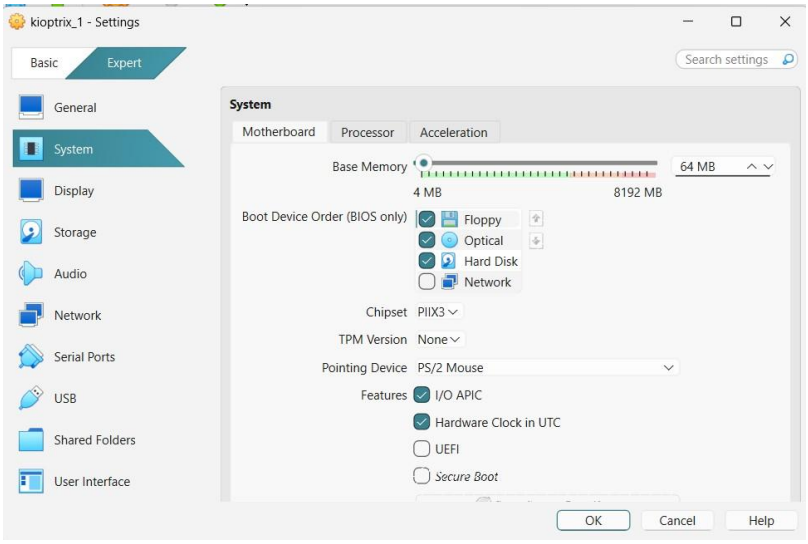



Fig : System Configuration

The network adapter was enabled and connected to the dedicated NAT Network (**NetSec**) to allow communication with the Kali Linux auditor machine.

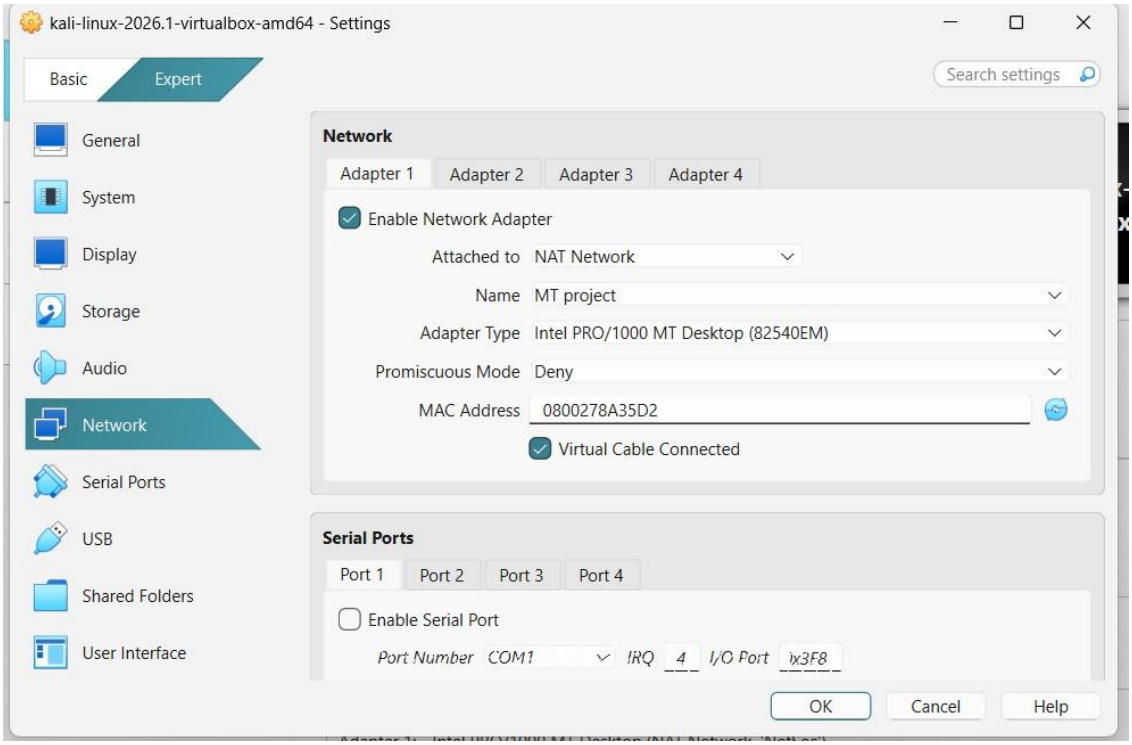
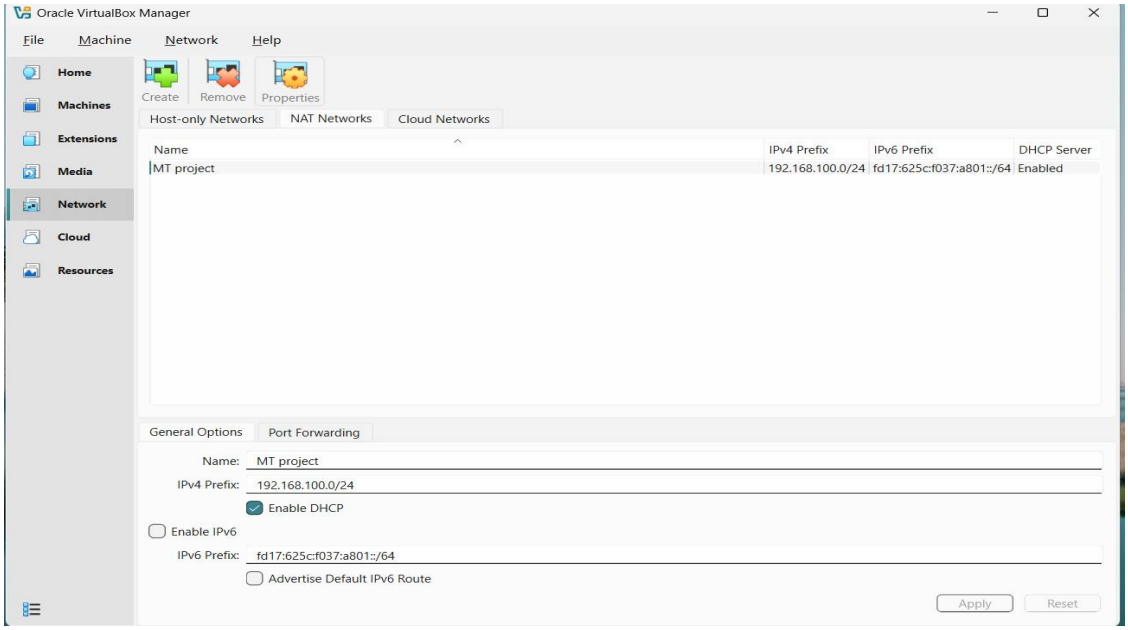



Fig: Network Adapter Configuration




NAT Network Configuration in VirtualBox

The Kioptrix Level 1 virtual machine booted successfully and displayed the login screen, confirming that the target system was ready for security assessment.

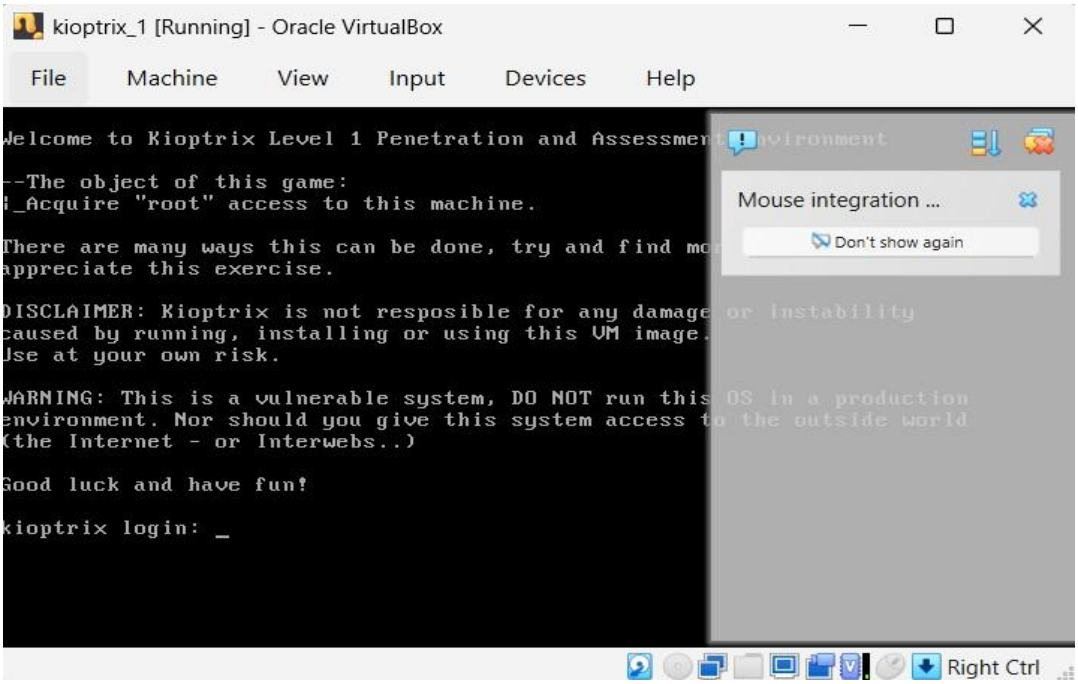



Fig : Successful Target VM Boot

## 2. System Discovery Results

The system discovery phase was conducted to identify the target system, open ports, running services, operating system details, and potential vulnerabilities. The IP address of the Kali Linux machine was first identified using the ifconfig command, which showed the auditor machine running on the **192.168.100.0/24** network.

A host discovery scan was performed using:

nmap -sn 192.168.100.0/24

The scan identified multiple active hosts, and the target system was found at **192.168.100.4**.

A basic port scan was then conducted:

nmap 192.168.100.4

The scan revealed several open ports including **22 (SSH), 80 (HTTP), 111 (RPCBind), 139 (Samba), 443 (HTTPS), and 1024 (RPC Status)**.

To gather additional information about the running services, service version detection was performed:

nmap -sV 192.168.100.4

The results showed that the target system was running **OpenSSH 2.9p2**, **Apache HTTP Server 1.3.20**, **Samba**, and other RPC-related services. Most of these software versions are outdated and may contain known vulnerabilities.

Operating system detection was carried out using:

sudo nmap -O 192.168.100.4

The scan identified the target as a **Linux-based system running Linux Kernel 2.4.x**.

Further enumeration was performed with an aggressive scan:

sudo nmap -A 192.168.100.4

The scan provided additional details such as SSL information, NetBIOS name (**KIOPTRIX**), HTTP server details, and SSH host information.

Finally, a vulnerability scan was executed using:

sudo nmap -sV --script=vuln 192.168.100.4

The scan reported several publicly known vulnerabilities associated with the detected services, indicating that the target system contains outdated software and weak security configurations.

## Interpretation of Findings

The discovery process revealed multiple open ports and outdated services running on the target machine. The presence of older versions of OpenSSH, Apache, Samba, and Linux Kernel 2.4.x suggests potential

security risks. The vulnerability scan further confirmed that several known weaknesses exist within the system, making it a suitable target for security assessment and analysis.

# 2.1 Identifying the Auditor Machine

First, the IP address of the Kali Linux auditor machine was identified using the `ifconfig` command. The assigned IP address was **192.168.100.3**.

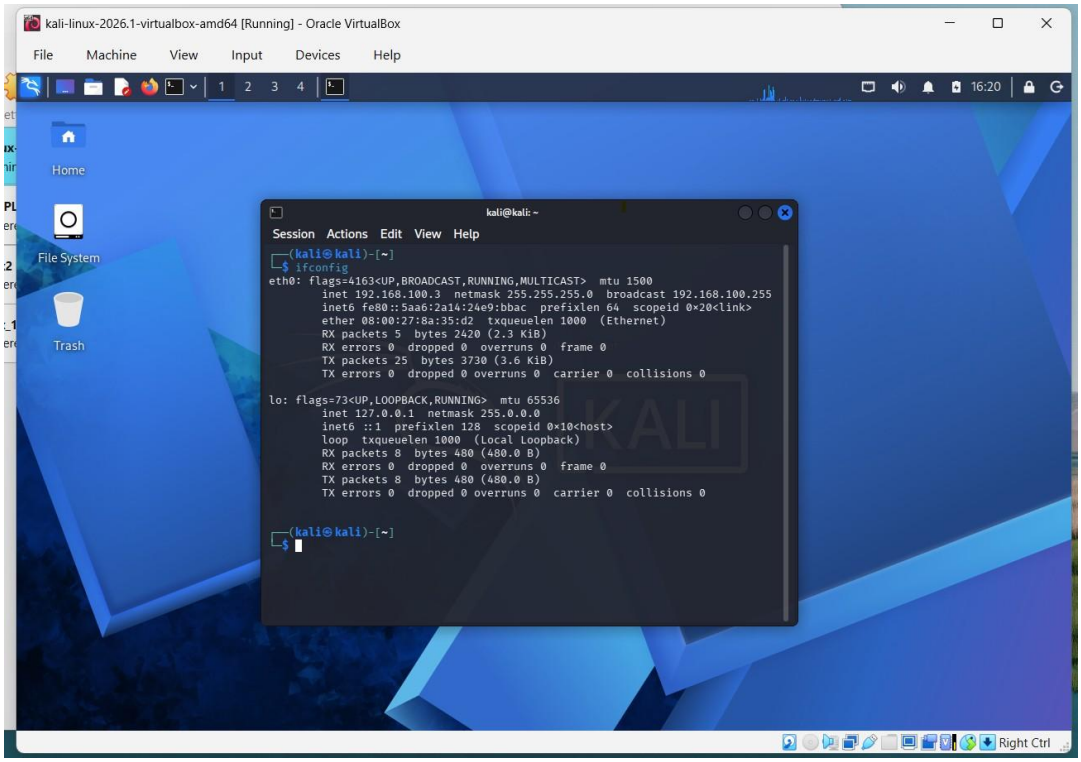



Fig: Kali Linux IP address using ifconfig.

# 2.2 Host Discovery

A host discovery scan was performed using Nmap to identify active devices within the isolated network.

nmap -sn 192.168.100.0/24

The scan revealed multiple active hosts. Among them, **192.168.100.4** was identified as the target system.

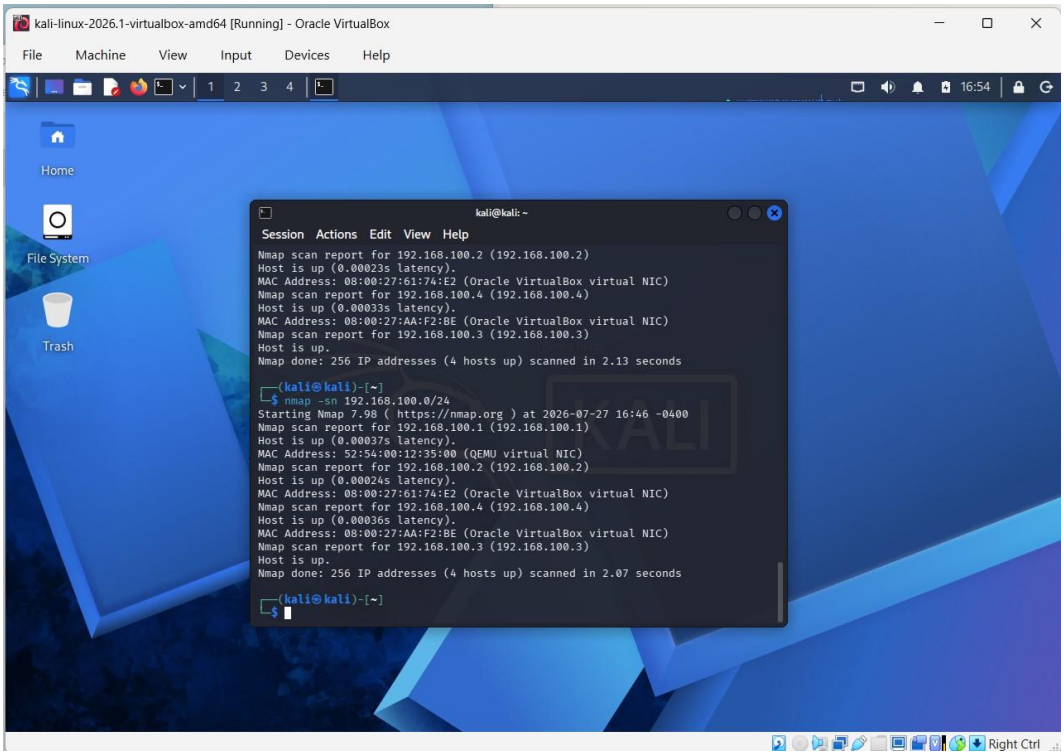


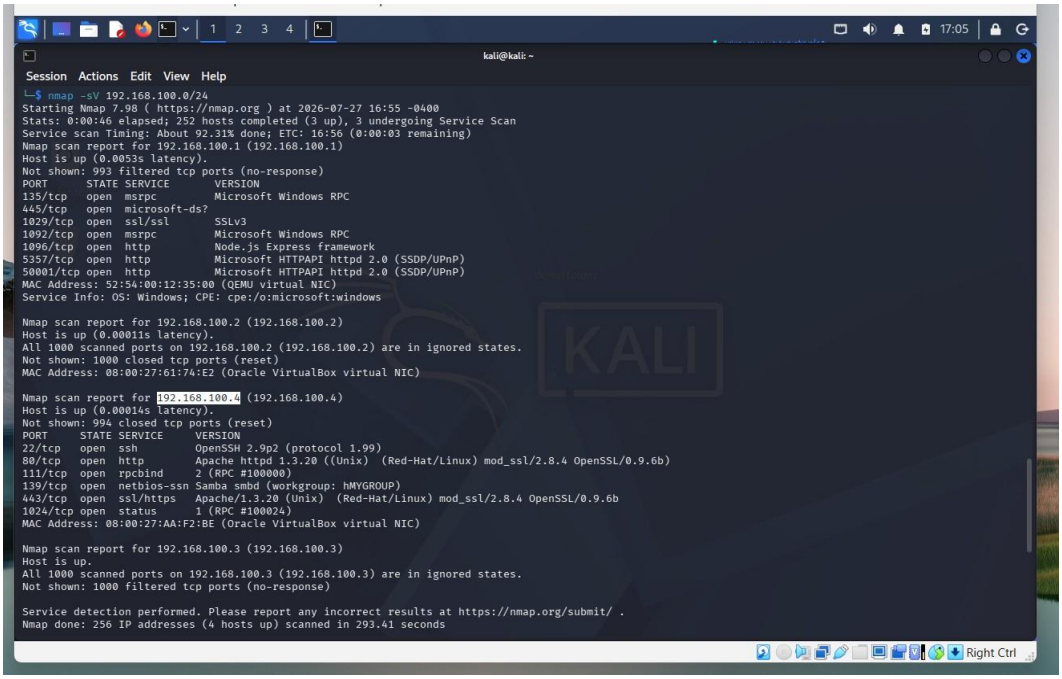

Fig: Host discovery Using Nmap

# 2.3 Target Identification

Service detection was performed across the network to determine which host corresponded to the Kioptrix target machine.

nmap -sV 192.168.100.0/24

The host at **192.168.100.4** was identified as the Kioptrix Level 1 system based on the discovered services and software versions.




# 2.4 Basic Port Scan

A basic port scan was conducted to identify open ports on the target system.

nmap 192.168.100.4

The scan revealed several open ports including SSH, HTTP, HTTPS, RPC, and Samba services.

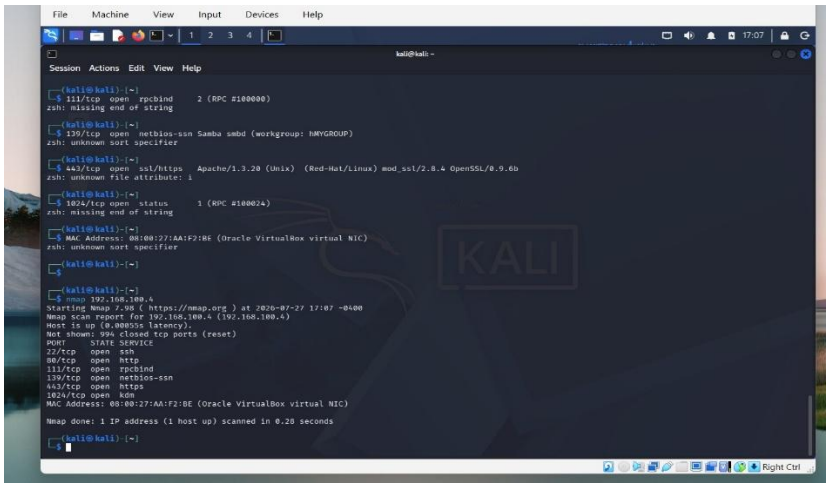



Fig: Basic port scan results.

# 2.5 Service Version Detection

To identify service versions running on the target, Nmap version detection was performed.

nmap -sV 192.168.100.4

## Open Ports and Services

| Port | State | Service | Version |
|---|---|---|---|
| 22/tcp | Open | SSH | OpenSSH 2.9p2 |
| 80/tcp | Open | HTTP | Apache 1.3.20 |
| 111/tcp | Open | RPCBind | RPC Service |
| 139/tcp | Open | Samba | Samba smbd |
| 443/tcp | Open | HTTPS | Apache SSL |
| 1024/tcp | Open | Status | RPC Service |

The results indicate that the target system is running multiple outdated services.

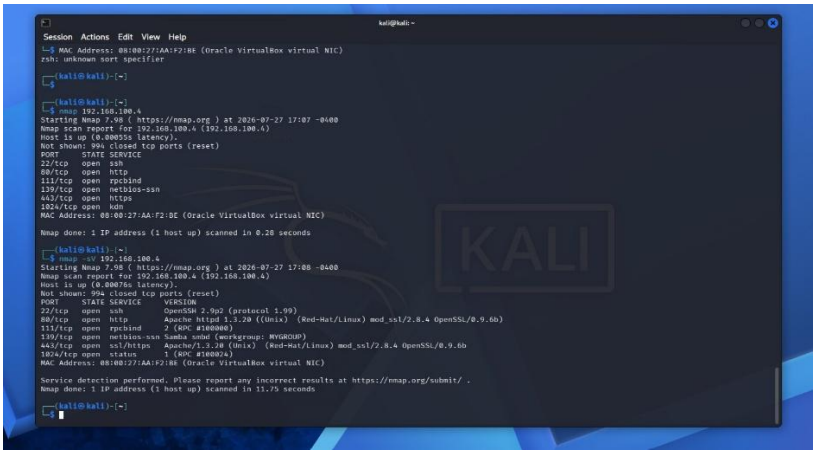



Fig: Service version detection.

# 2.6 Operating System Detection

Operating system detection was performed to identify the underlying platform.

sudo nmap -O 192.168.100.4

Nmap identified the operating system as **Linux Kernel 2.4.x**, indicating the use of an older Linux version.

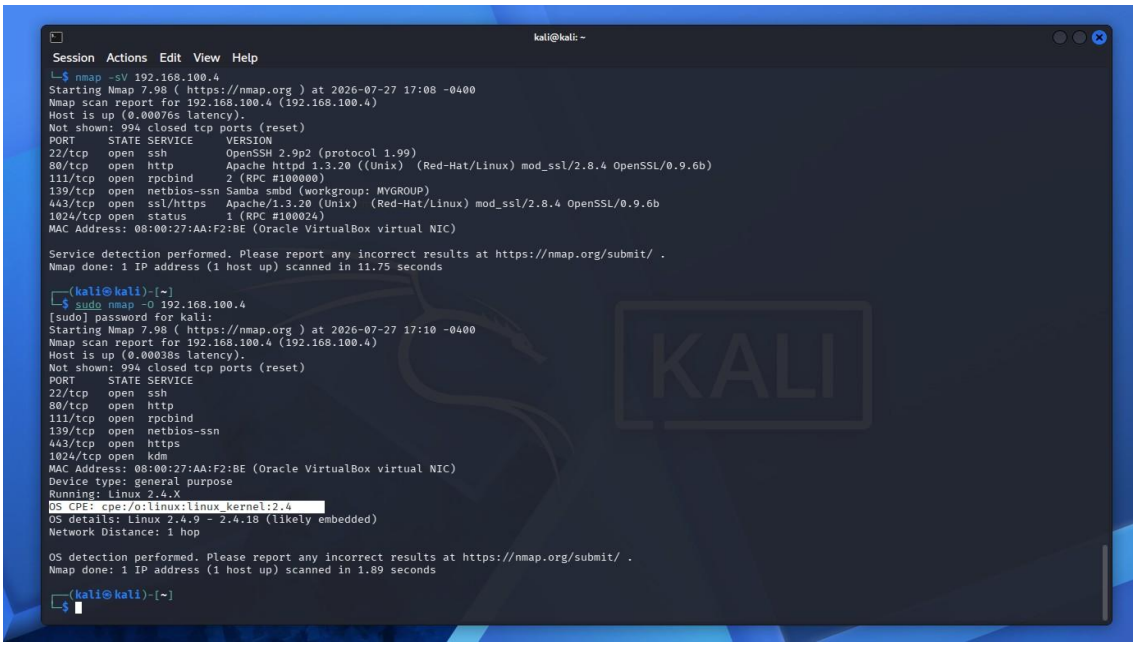



Fig: Operating system detection.

# 2.7 Aggressive Scan and Enumeration

An aggressive scan was performed to gather more detailed information about the target system.

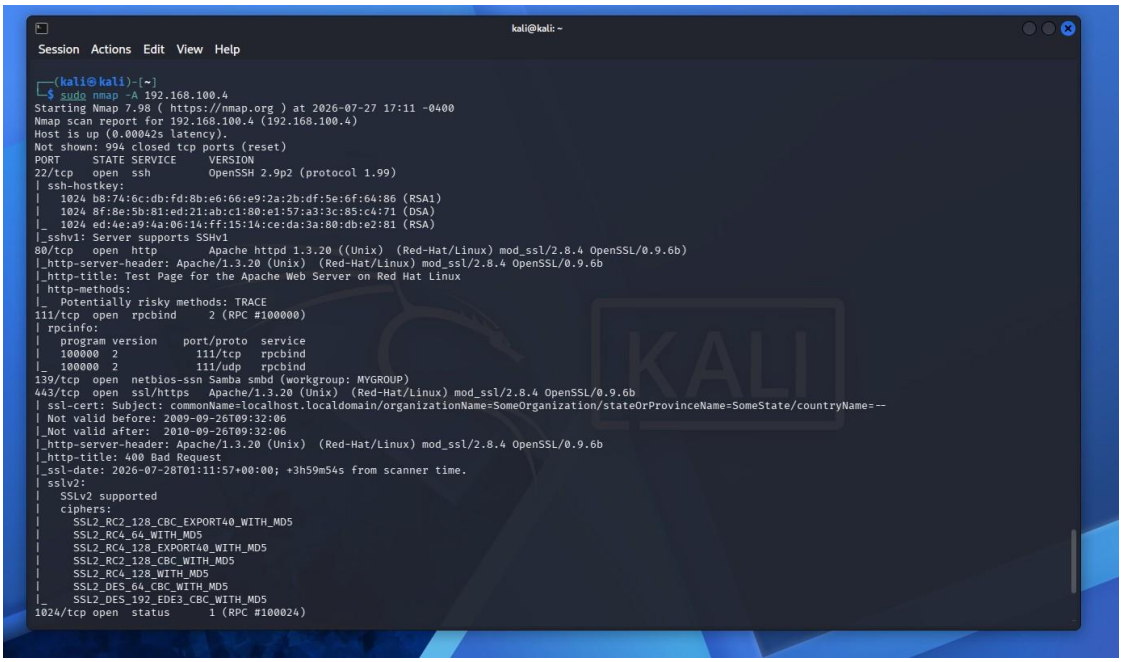
sudo nmap -A 192.168.100.4

The scan revealed:

- Apache web server details
- SSH host key information
- NetBIOS hostname (KIOPTRIX)

- SSL certificate information
- Supported SSL protocols
- Additional service enumeration information

The scan also showed that the server supports older SSL versions and uses outdated software components.



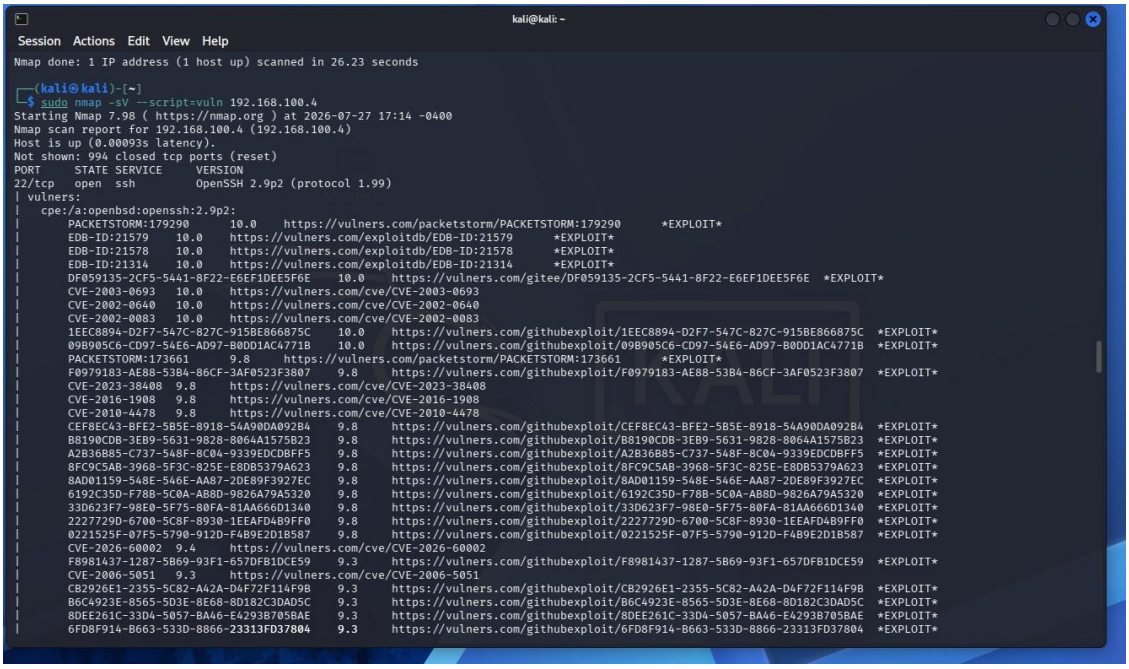



Fig: Aggressive scan results

# 2.8 Vulnerability Scan

A vulnerability assessment was performed using Nmap vulnerability detection scripts.

sudo nmap -sV --script=vuln 192.168.100.4

The scan reported multiple known vulnerabilities associated with the detected services, including outdated OpenSSH, Apache, and SSL implementations. Several CVEs and publicly documented security issues were identified.

The vulnerability scan also indicated the presence of weak or outdated security configurations, increasing the risk of unauthorized access and exploitation.

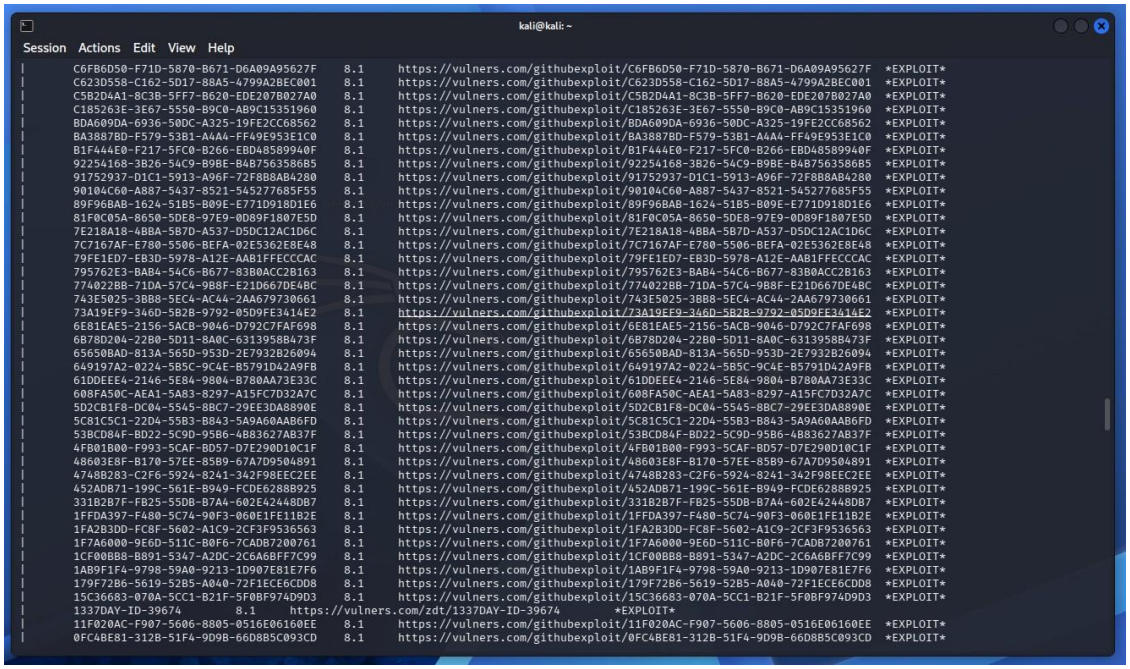



Fig :Vulnerability scan results (Part 1).

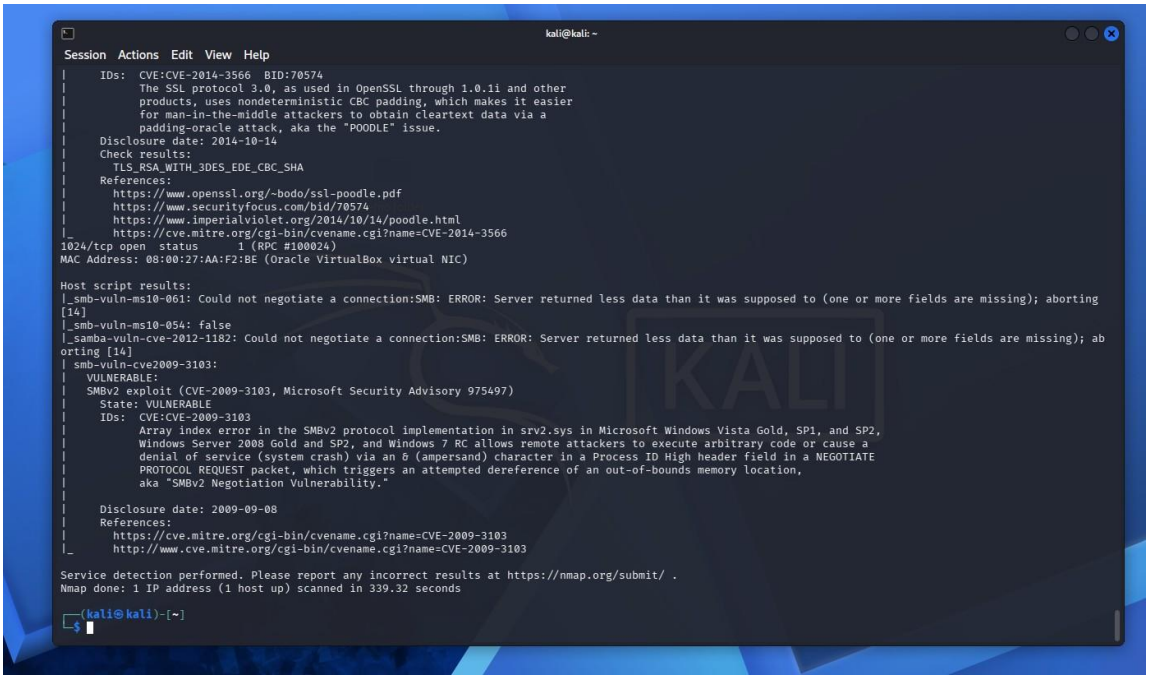



Fig: Vulnerability scan results (Part 2).

# 3. Network Communication Observation

Wireshark was used to observe and analyze network communication between the Kali Linux auditor machine and the Kioptrix target system. Packet capturing was started on the **eth0** interface connected to the isolated NAT network.

To generate network activity, ICMP traffic was created by sending ping requests from Kali Linux to the target machine:

ping 192.168.100.4

Wireshark successfully captured the ICMP Echo Request and Echo Reply packets exchanged between the two hosts. The captured packets showed source and destination IP addresses, sequence numbers, packet lengths, and response times, confirming successful communication between the systems.

To observe application-level traffic, the target web server was accessed through a web browser using the HTTP service running on the target machine. During this activity, Wireshark captured the HTTP packets exchanged between the client and the web server.

### Protocol Analysis

The observed protocols included:

- ICMP (Internet Control Message Protocol)
- HTTP (Hypertext Transfer Protocol)
- TCP (Transmission Control Protocol)

## Information Visible During Transmission

The packet capture revealed source and destination IP addresses, packet headers, HTTP requests, server responses, and response status codes. Because HTTP traffic is unencrypted, the exchanged web requests and responses were directly visible in the captured packets.

## Interpretation of Findings

The analysis confirmed successful communication between Kali Linux and the target system. Both ICMP and HTTP traffic were captured and examined using Wireshark. The results demonstrate how network traffic can be monitored and analyzed, and they highlight the importance of using encrypted communication protocols to protect sensitive information during transmission.

Wireshark was launched on the Kali Linux machine, and the **eth0** interface was selected to capture network traffic within the isolated NAT network.

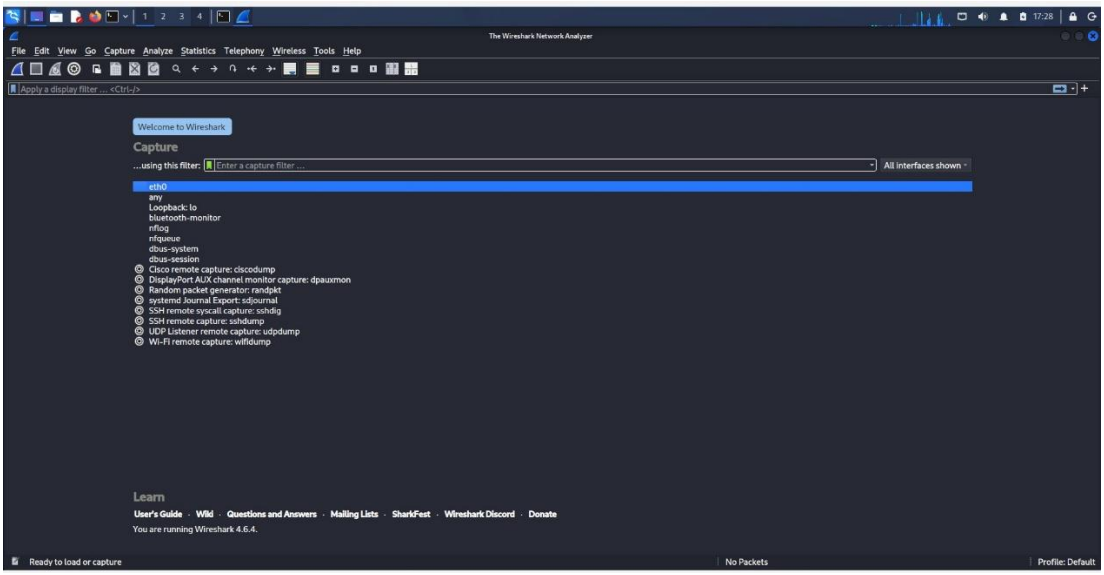



Fig: Opening Wireshark for Packet Capture

ICMP traffic was generated by sending ping requests from the Kali Linux machine (**192.168.100.3**) to the Kioptrix target system (**192.168.100.4**) to verify connectivity.

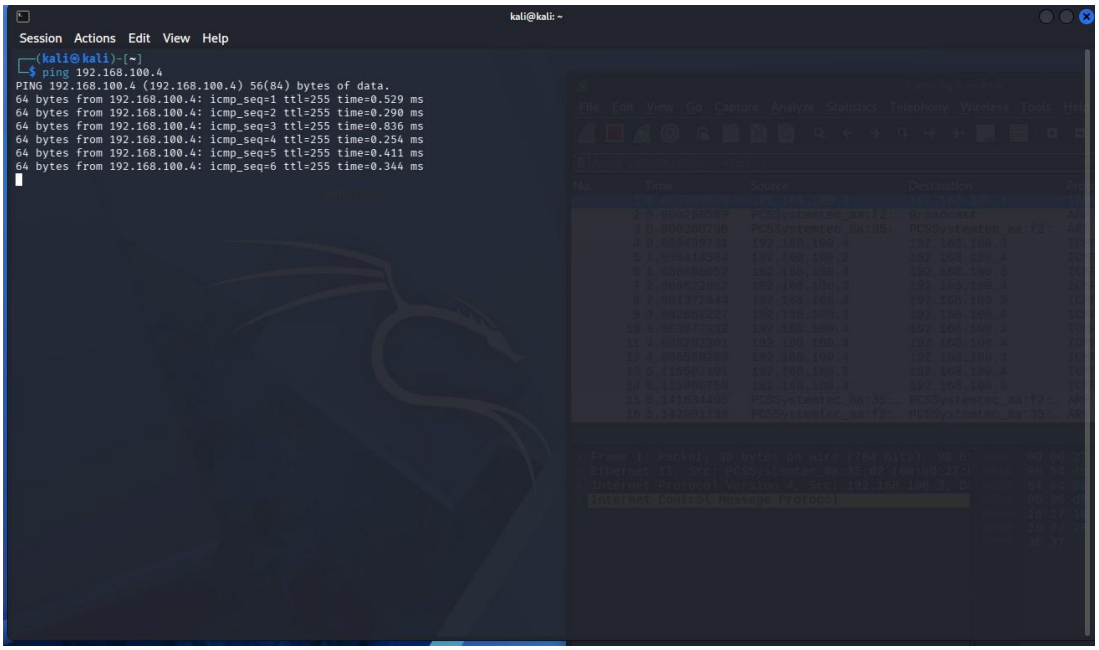



Fig : Generating ICMP Traffic

Wireshark successfully captured ICMP Echo Request and Echo Reply packets exchanged between the auditor machine and the target system, confirming active communication.

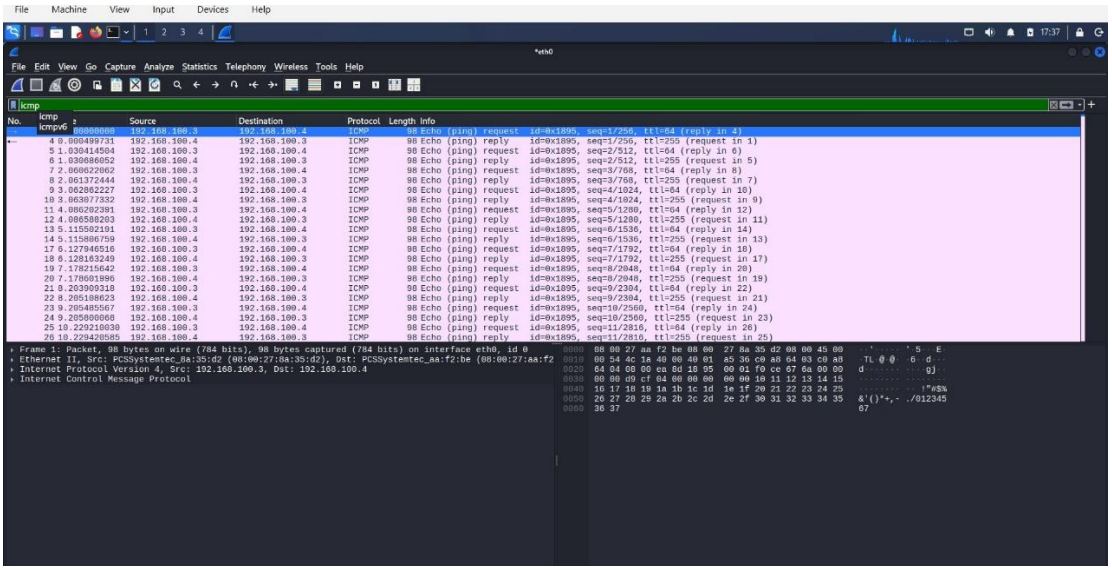



Fig: Captured ICMP Packets

A captured ICMP packet was analyzed in detail to examine source and destination IP addresses, sequence numbers, identifiers, and response time information.

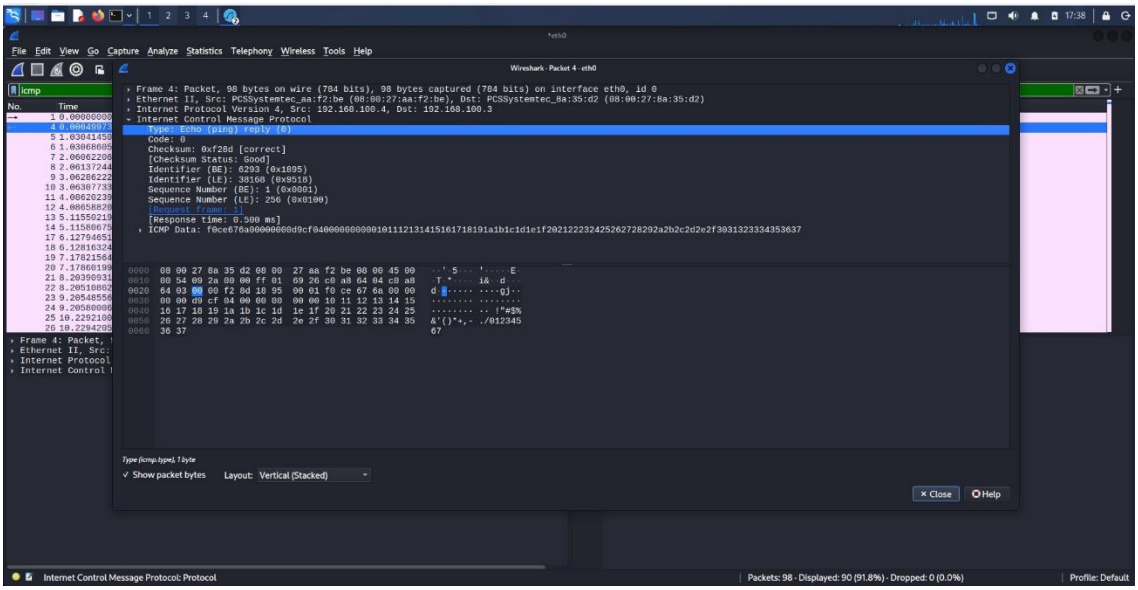


Fig: Analyzing ICMP Packet Details

The target web server was accessed through a web browser to generate HTTP traffic while Wireshark continued capturing the communication.

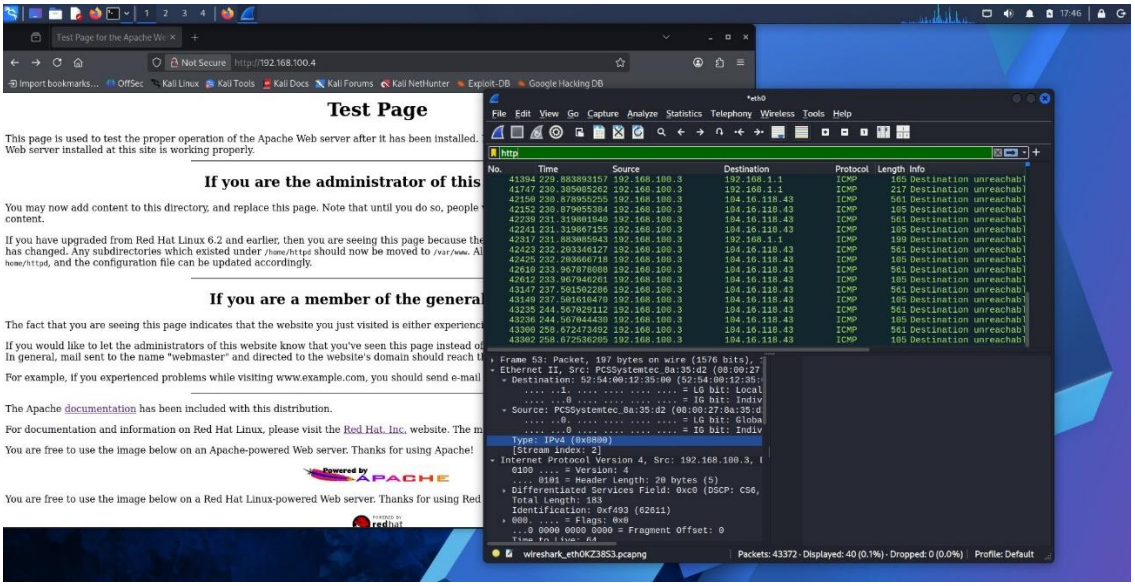


Fig: Generating HTTP Traffic

An HTTP display filter was applied in Wireshark to analyze web requests and responses exchanged between the Kali Linux machine and the target web server.

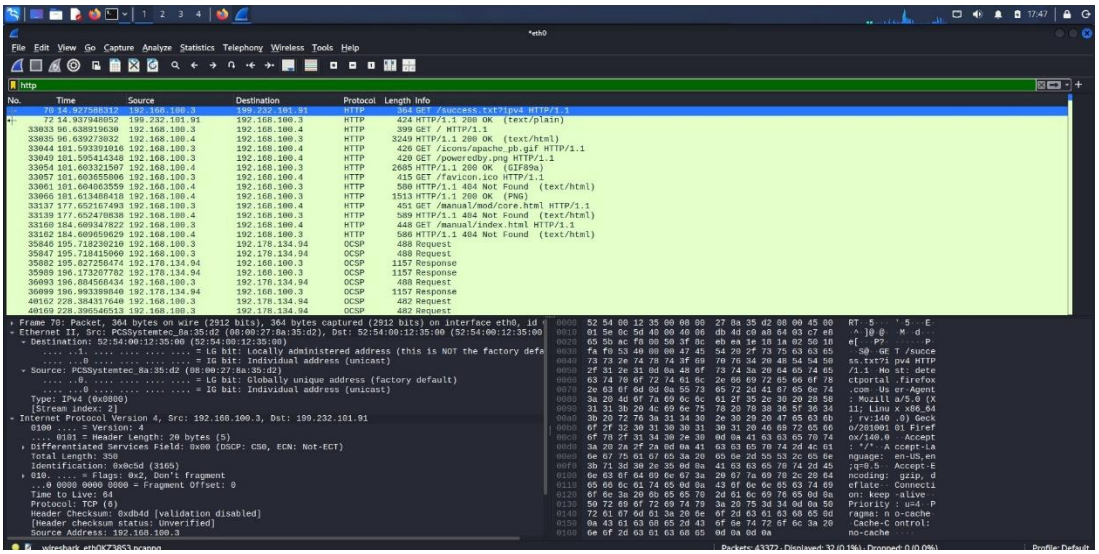


Fig: Filtering and Analyzing HTTP Packets

## 4. Authentication Strength Evaluation

The authentication evaluation phase was conducted to assess the security of user accounts and authentication mechanisms on the target system. During the discovery phase, an outdated Samba service was identified, making it a potential entry point for further investigation.

Several enumeration and exploitation attempts were performed to gain access to the target machine. Not all attempts were successful; however, each step provided valuable information about the target environment and helped identify the most suitable attack path. After reviewing the detected Samba version and researching available vulnerabilities, different Metasploit modules and payload configurations were tested.

Eventually, a successful exploitation method was identified, resulting in root-level access to the target system. This access allowed further examination of authentication-related files and the evaluation of password security on the system.

The Metasploit Framework was launched using the `msfconsole` command to begin vulnerability assessment and exploitation activities.

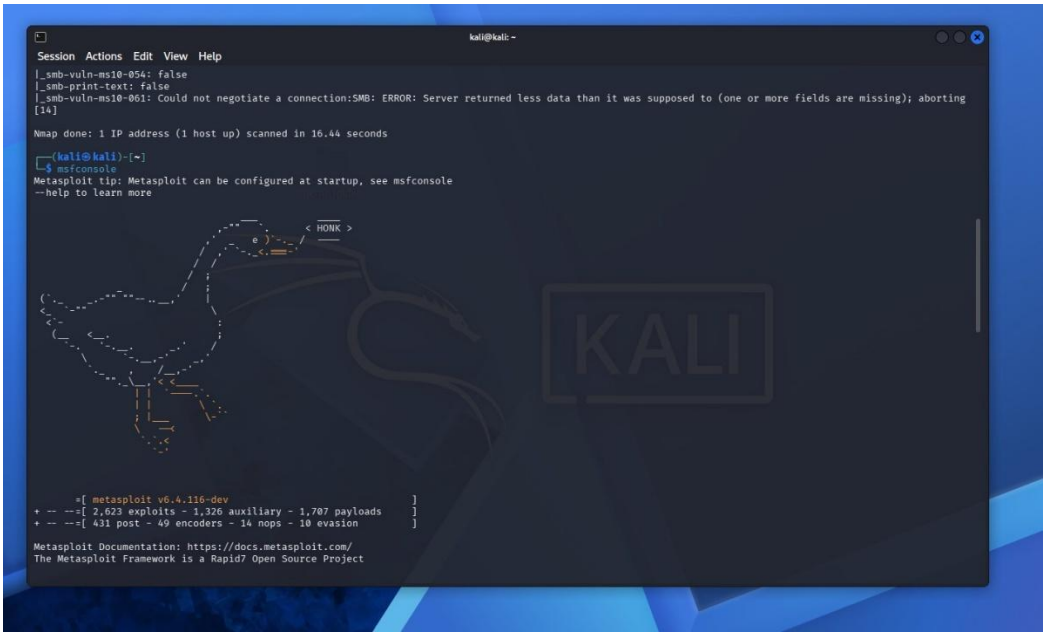



Fig: Launching Metasploit Framework

A search was performed within Metasploit to identify Samba-related modules that could be used against the target service.

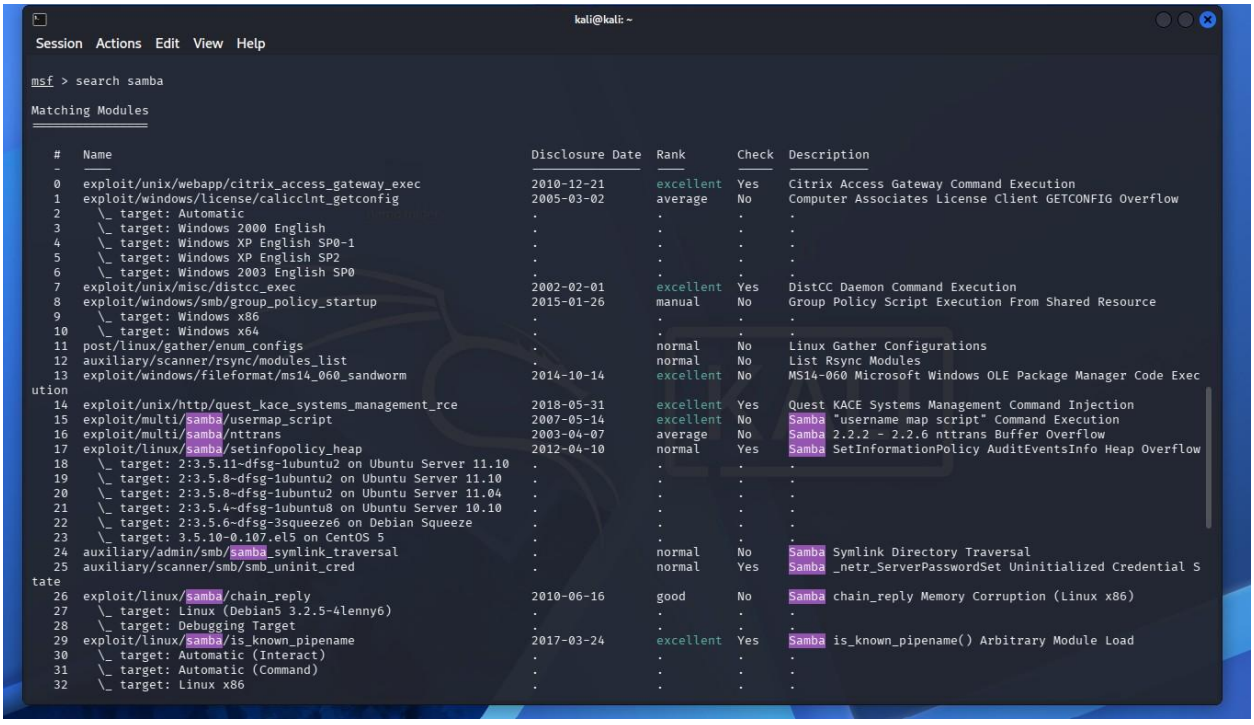



Fig: Searching for Samba Modules

The list of available Samba exploit modules was examined to identify potential attack vectors compatible with the target system.

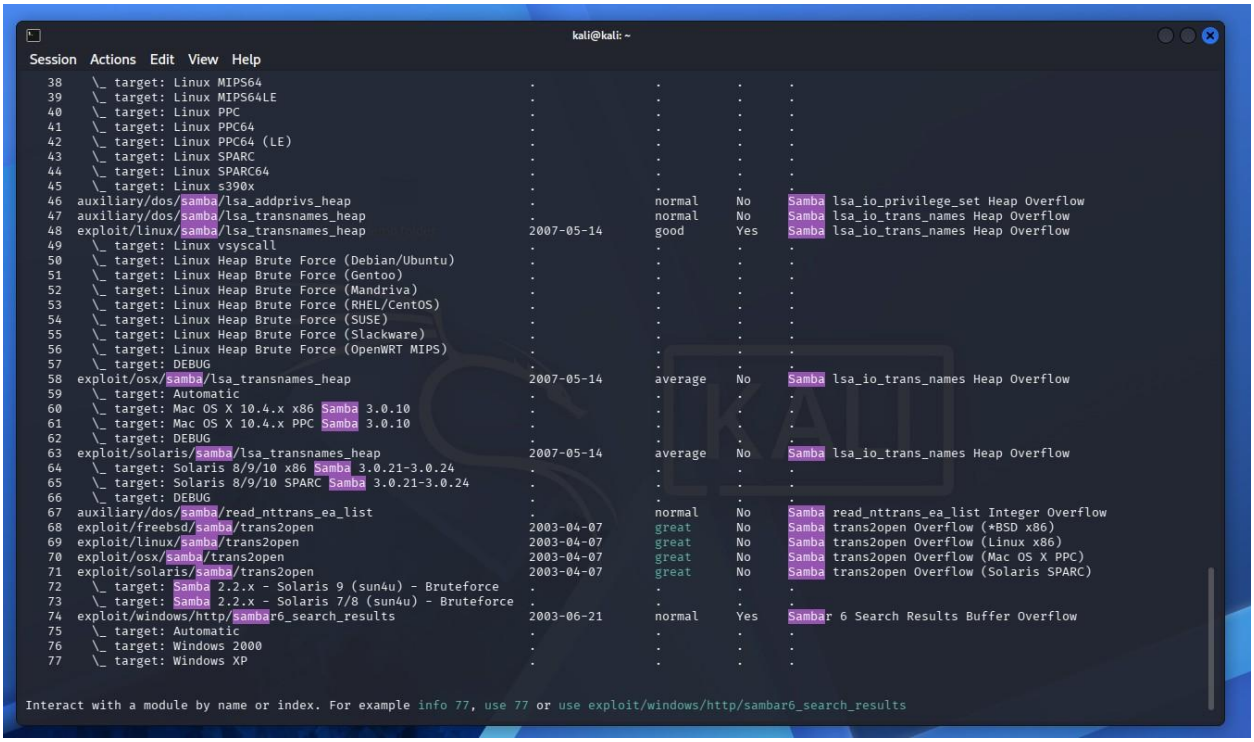



Fig: Reviewing Available Samba Exploits

# SECURITY RECOMMENDATIONS

## Weakness 1: Outdated Services

Evidence

- OpenSSH 2.9p2
- Apache 1.3.20
- OpenSSL 0.9.6b
- Samba Service

Risk

These versions contain publicly known vulnerabilities.

Recommendation

• Apply security patches regularly.

• Upgrade all outdated services.

### Weakness 2: Unencrypted HTTP Communication

Evidence

HTTP traffic was visible during packet capture.

Risk

Attackers may intercept sensitive traffic.

Recommendation

• Replace HTTP with HTTPS.

• Use strong TLS configurations.

---

### Weakness 3: Weak Password Practices

Evidence

Passwords can be recovered using John the Ripper.

Risk

Unauthorized access to user accounts.

Recommendation

• Enforce strong password policies.

• Require password complexity.

• Enable multi-factor authentication.

---

Additional Recommendations

• Disable unnecessary services.

• Restrict SMB access.

• Implement access controls.

• Conduct regular vulnerability assessments.

• Maintain updated software versions

The `linux/samba/trans2open` exploit module was selected based on the Samba service identified during enumeration.

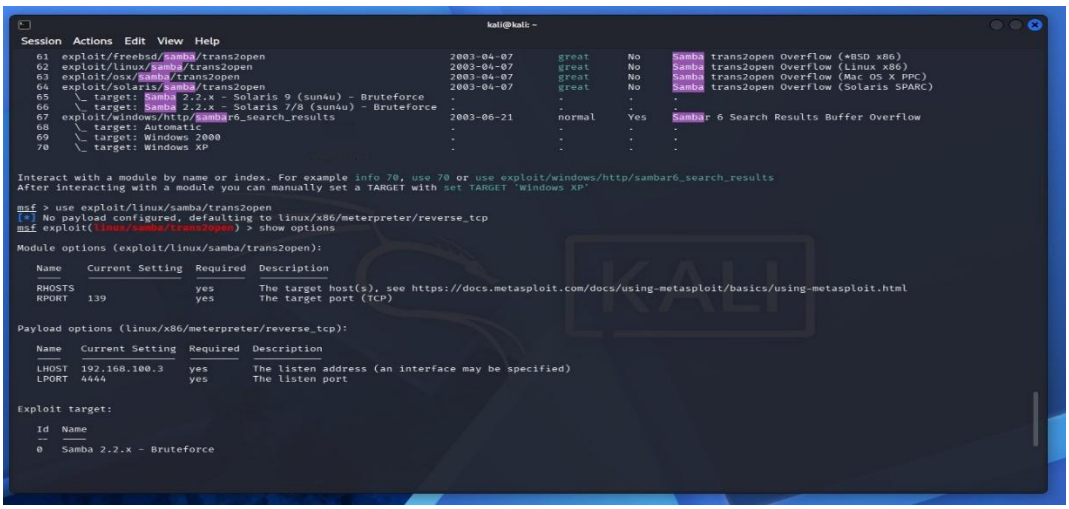



Fig: Loading the Samba Trans2Open Module

The target IP address and exploit settings were configured to prepare the module for execution.

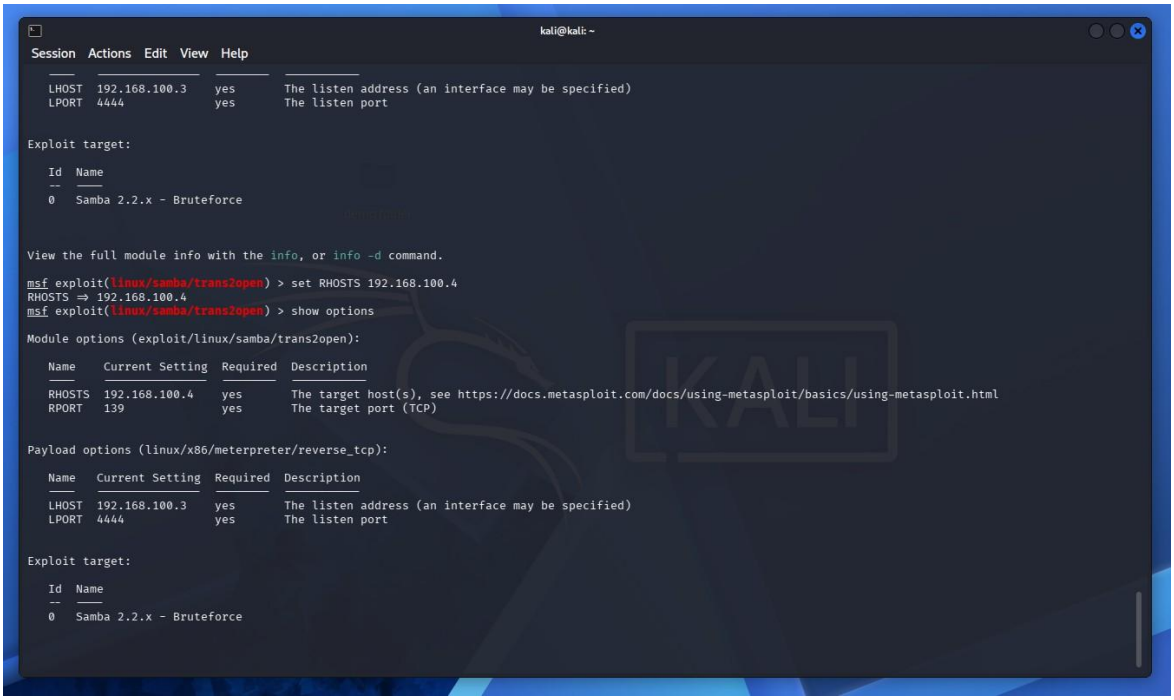



Fig: Configuring Exploit Parameters

The exploit was executed using the default payload. However, the Meterpreter sessions repeatedly closed, indicating that the exploitation attempt was unsuccessful.

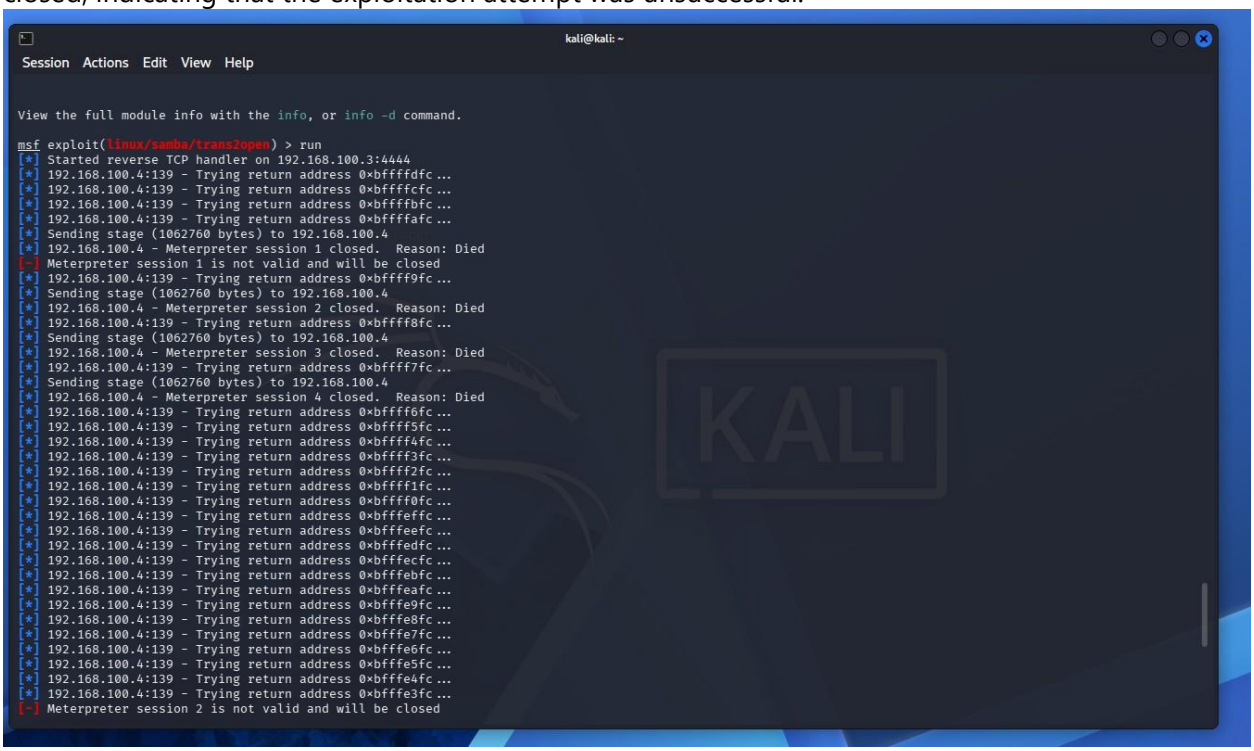


Fig: Initial Exploitation Attempt

The first exploitation attempt did not provide access to the target system. Although the exploit targeted a known Samba vulnerability, the selected payload was unable to establish a stable session. As a result, additional enumeration and exploit verification steps were performed to identify a more suitable approach.

The `smb_version` scanner module was used to determine the exact version of the Samba service. The scan identified the target as running **Samba 2.2.1a**.

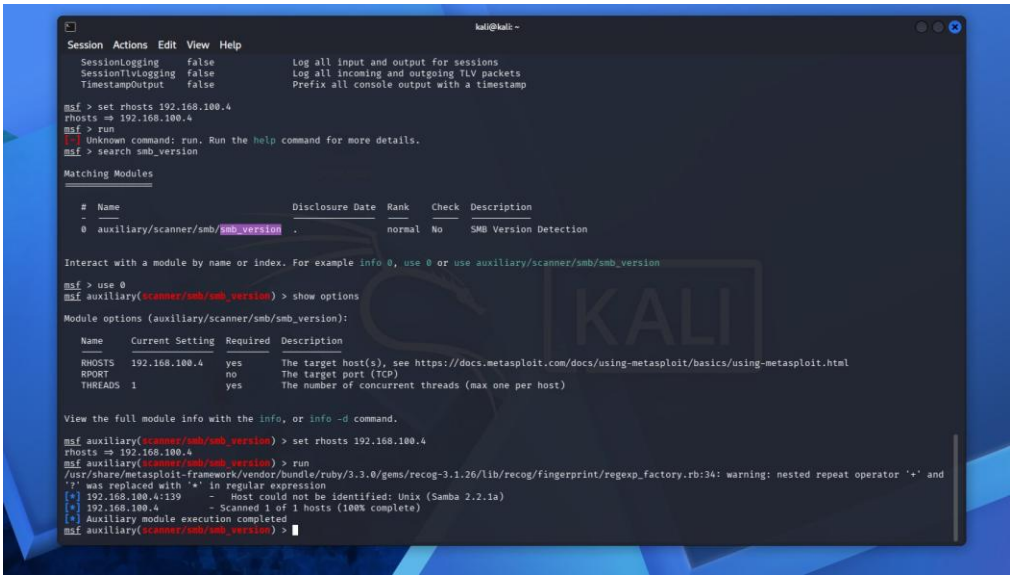



Fig: Identifying the Samba Version

Information about the detected Samba version and its associated vulnerabilities was reviewed to confirm that the Trans2Open vulnerability was applicable to the target environment.

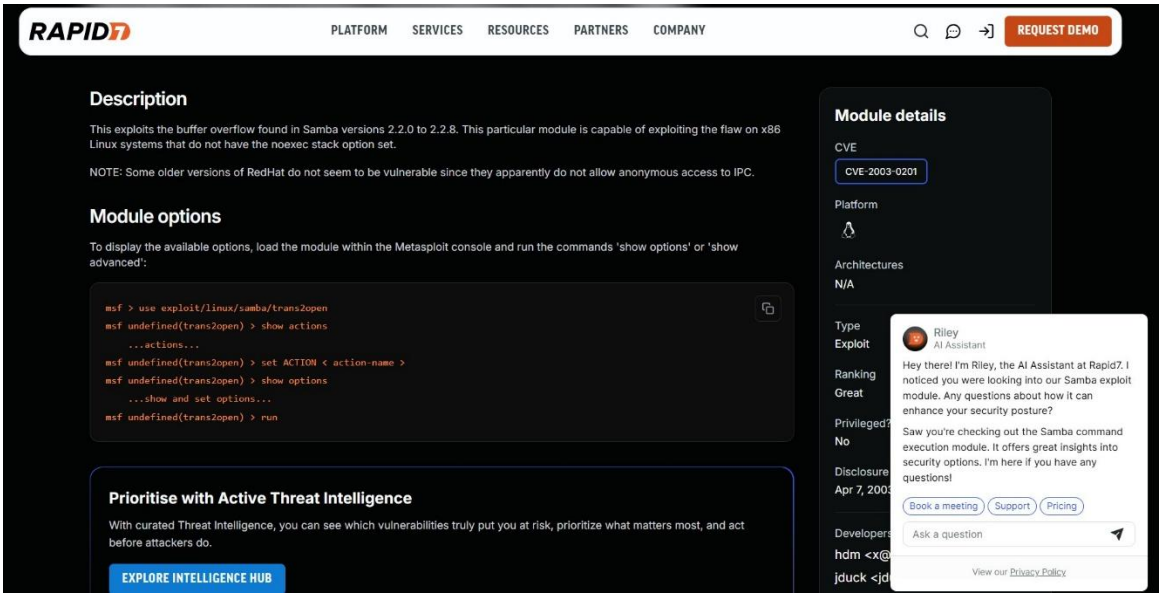



Fig: Exploit Verification and Research

After modifying the exploit configuration and selecting a different payload, the exploitation was successful. A command shell session was established, and the `id` and `whoami` commands confirmed root-level access to the target system.

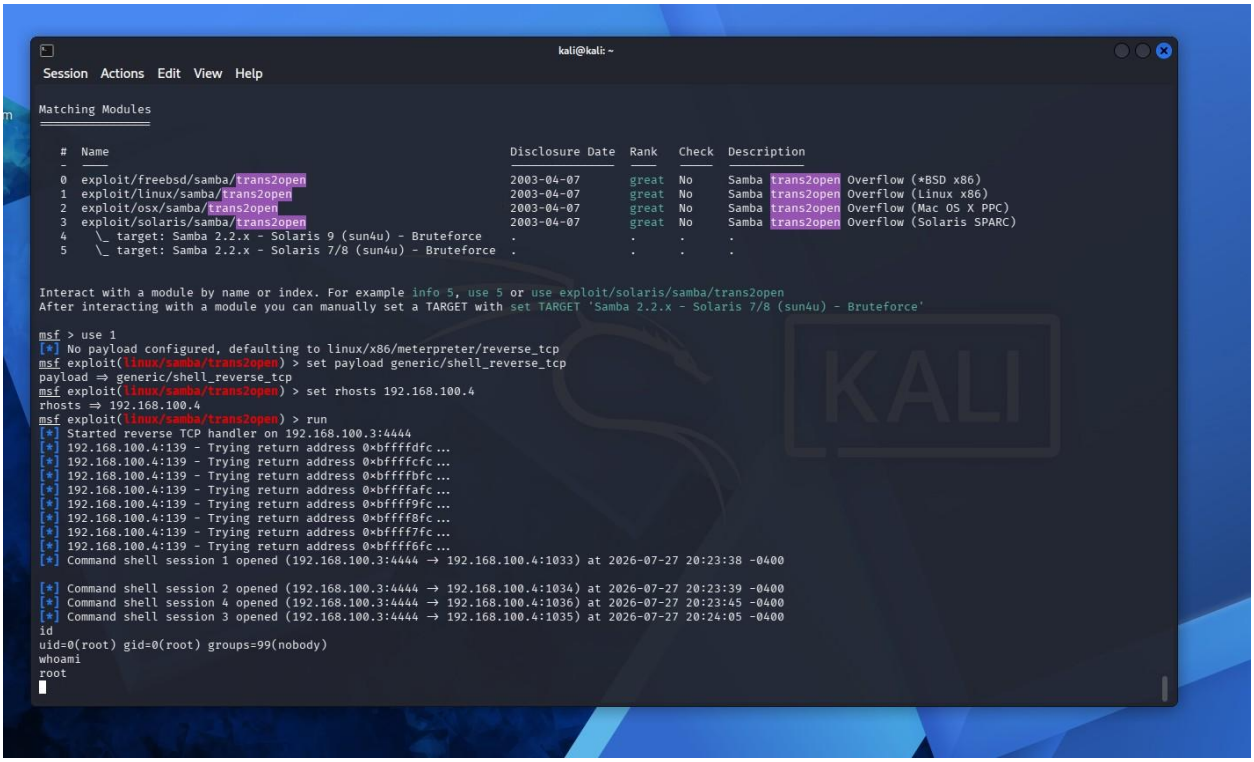



Fig: Successful Exploitation and Root Access

The authentication evaluation process demonstrated that outdated and vulnerable services can provide attackers with a path to administrative access. While the initial exploitation attempt failed, further analysis and proper exploit configuration ultimately resulted in successful root access, allowing the assessment of authentication-related information stored on the target system.